

Q5	Identify preventive, detective and corrective mitigations	5 Marks
-----------	--	----------------

Objective: For the top risks, propose controls in three categories: preventive (stop it), detective (spot it) and corrective (recover from it).

Step-by-Step Algorithm

Step	Phase	Action	Command / Tool	What You Should See
1	SETUP	Take the highest-risk items from the Q4 matrix.	Q4 risk matrix	Top risks selected
2	ANALYSE	For each, list a preventive control that would stop the attack.	Control catalogue	Preventive control
3	ANALYSE	Add a detective control that would raise an early alert.	Control catalogue	Detective control
4	ANALYSE	Add a corrective control that limits or reverses damage.	Control catalogue	Corrective control
5	TEST	Check each control is realistic and maps back to a risk.	—	Controls validated
6	REPORT	Record the three-column control table.	Table template	Mitigation table

Phase key: ● SETUP ● CONFIGURE ● EXECUTE ● TEST ● ANALYSE ● REPORT ● FINISH

Worked Example (with sample values & output)

Mitigation controls (Acme HealthCare)

Risk	Preventive (stop it)	Detective (spot it)	Corrective (recover)
Data theft	Email filtering + MFA	DLP alerts on large exports	Breach notification + credit monitoring
Ransomware	Patch servers + app allowlist	EDR behaviour alerts	Offline backups + restore plan

Each row covers all three control types, so even if prevention fails, the attack can still be detected and recovered from.



Colonial Pipeline Hack

Risk	Preventive	Detective	Corrective
Data theft	• Enforce Multi-Factor Authentication (MFA) across all endpoints, VPNs, and cloud keys. • Implement Least-Privilege Access to restrict data visibility to only required roles. • Conduct Immutable, Air-Gapped Backups that cannot be modified or wiped by hackers. • Run continuous automated patch management for all public-facing OS and software.	• Egress Monitoring: Set up automatic alerts for unusually large outbound file transfers. • Database Activity Monitoring (DAM): Track and log all admin SQL queries and database export attempts. • Anomalous Login Alerts: Flag accounts logging in from unusual geographic locations or at odd hours.	• Instantly lock down compromised user accounts to stop ongoing data exfiltration. ○ Credential Revocation: ○ Legal & Regulatory Notifications: Execute compliance protocols (like GDPR or HIPAA notifications) to inform affected parties. ○ Digital Forensic Remediation: Trace system logs to identify the exact files stolen and patch the security leak.
Ransomware	• Immutable Backups: Maintain write-once-read-many (WORM) backups that ransomware cannot encrypt or delete. • Network Segmentation: Separate critical operational servers from standard	• Endpoint Detection & Response (EDR): Deploy CrowdStrike Falcon or Microsoft Defender for Endpoint to catch and kill automated file-encryption behaviors in real time.	• ○ Automated Isolation: Disconnect infected machines from the local network instantly to halt lateral movement. ○ Disaster Recovery (DR) Activation:



	employee workstation networks. • Email Authentication: Deploy strict SPF, DKIM, and DMARC protocols to block phishing emails carrying malware. ?	• File Integrity Monitoring (FIM): Alert security teams the moment core system files or extensions are modified. • Canary Decoys: Place hidden decoy files on servers that trigger an instant quarantine if ransomware touches them. ?	Failover primary business operations to safe, uninfected cloud environments. ○ Clean Bare-Metal Restores: Wipe compromised endpoints completely and reinstall clean system images from verified backups.
--	---	---	--

Your Output / Screenshot (paste result here):

Breach Incident Profile & Entry Vector

- **The Victim:** Colonial Pipeline (Major US Energy Infrastructure Operator).
- **The Threat Group:** DarkSide (An affiliate-driven Cybercrime Syndicate).
- **Initial Entry Method:** A compromised, legacy Virtual Private Network (VPN) account.
- **The Vulnerability:** The account used a reused password found on the dark web and lacked Multi-Factor Authentication (MFA).
- **Data Theft Volume:** 100 Gigabytes of highly sensitive corporate data exfiltrated in under 2 hours.
- **The Ransom Demand:** 75 Bitcoin (equivalent to roughly \$4.4 Million USD at the time) paid to retrieve the decryption keys.

